

## User Manual - after you use this template

You just created a repo from this template. This page tells you **exactly what to do, in order**, what **not** to do, and what each result means.

This template gives a new repo the following, working out of the box once it is on GitHub:

- **Security** - blocks committed secrets and runs Semgrep static analysis..

Two checks are meant to be **required before merge**: security Everything else is **advisory** (it warns, never blocks).

### Do these once, right after creating the repo

Run them in order. Steps 1-3 take five minutes; 4-5 need a repo admin.

| # | Do this                                                                                                  | Why                                                                                                         |
|---|----------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| 1 | make install                                                                                             | Installs deps <b>and turns on the local secret-scanning git hooks</b> . Without it, the hooks sit inactive. |
| 3 | Set reviewers - edit <b>.github/CODEOWNERS</b> , replace the example names with your team / GitHub teams | Otherwise code-owner review requests go nowhere.                                                            |
| 4 | Adjust the <b>Makefile</b> for your stack if the defaults don't fit                                      | CI runs the same make targets; keep them working.                                                           |

### What runs automatically (you do nothing)

Once the repo is on GitHub, every push and pull request triggers:

- security/secret-scan, security/sast, security/security - secret + SAST gate
- quality/pr-title, quality/pr-size, quality/duplicate-code - advisory quality

### Do / Don't

#### DO

- **Run make install on every machine** that will commit - that is what activates the local secret hooks per clone.
- **Name branches** feature/\*, fix/\*, hotfix/\* - branch-flow expects these prefixes.
- **Write Conventional-Commit titles** (feat:, fix:, chore:...)
- **Rotate any secret that ever reached git** - deleting it from a file is not enough; the history still has it.

#### DON'T

- **Don't rename the jobs security or branch-flow**. They are required-check names that setup-branch-protection.sh depends on by name. Renaming them silently breaks the merge gate.
- **Don't rename .github/dependabot.yml** - Dependabot only reads that exact path; rename it and dependency updates stop.
- **Don't bypass the hooks casually** (git commit --no-verify). CI will still catch a leaked secret, but you have removed your first line of defense.

- **Don't expect tests, lint, or formatting to run** - this template intentionally ships none (no generic-across-languages tool). Add your stack's own test/lint setup if you want them.
- **Don't merge to main directly** if your model has stages - promote through them; branch-flow will block a skip.

## Reading the signals

What each check result means when you see it on a PR:

| You see                           | It means                                                          | What to do                                                                                             |
|-----------------------------------|-------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| security/security - Yes           | No secrets, SAST clean                                            | nothing                                                                                                |
| security/secret-scan - No         | A credential is in the diff                                       | <b>Remove it, rotate it.</b><br>Genuine placeholder?<br>append pragma:<br>allowlist secret to the line |
| security/sast - No                | Semgrep flagged a code vulnerability                              | Review the finding; fix or justify                                                                     |
| quality/* warnings (yellow)       | Advisory only (oversized PR, non-conventional title, duplication) | Address if reasonable; they never block                                                                |
| a job stuck <b>Queued</b> forever | No runner is available for it                                     | Check your runner is online (this template's jobs use runs-on: self-hosted - see note below)           |

## Runner note (important)

This template's workflows use **runs-on: self-hosted**. That means **a self-hosted GitHub Actions runner must be registered and online** for your repo or org, with the tools the jobs need installed (git, bash, python3+pip, node+npx, make).

## Where things live

| Thing              | File                                           |
|--------------------|------------------------------------------------|
| Reviewers          | .github/CODEOWNERS                             |
| Secret scanner     | scripts/secret-scan.sh (called by hooks + CI)  |
| Hook activation    | scripts/install-hooks.sh (run by make install) |
| Dependency updates | .github/dependabot.yml                         |